

QUIETKEY QK-2

System & Device Blueprint

Revision QK2-04 - Consolidated Canonical Edition

Status	Canonical for the QuietKey system, wallet structure, terminal, setup, recovery, security model, inheritance
Effective date	15 August 2026
Supersedes	QK2-03 and all earlier QK2 system/device blueprints, reconciliation deltas and reflows
Protocol authority	docs/cloakvault-protocol-v3.md + docs/cloakvault-v3-test-vector.json
Classification	EXPERIMENTAL - TEST USE ONLY - NOT FOR REAL FUNDS UNTIL GATES A-C COMPLETE

Authority rule. This document is the single current system-and-device blueprint. Earlier QuietKey/CloakVault project blueprints are historical records and MUST NOT be used as implementation inputs. Protocol constants remain governed by the frozen v3 normative specification and machine-readable test vector. Section 1.3 below is a readable, generated summary and MUST be CI drift-checked against those authoritative artifacts. If this document and the normative protocol specification disagree about a protocol constant, the normative specification wins and this document is defective.

Product thesis

QuietKey is an air-gapped Bitcoin cold-storage system built around three deliberately ordinary-looking objects: a printed document, a bank-card-sized smart card, and a scientific calculator.

The printed document resembles an ordinary web-printed recipe. The card resembles an ordinary bank, loyalty or transport card. The terminal resembles - and normally functions as - a scientific calculator.

No single ordinary object is sufficient to spend.

Hide your Bitcoin in plain sight.

QuietKey does not attempt to make cryptography invisible to forensic analysis. Its camouflage is a discretion layer intended to reduce recognition, association and opportunistic discovery. Cryptographic security never depends upon the camouflage.

The terminal holds no wallet secret at rest. Losing or destroying the terminal does not lose the wallet.

1. SYSTEM ARCHITECTURE

1.1 The three objects

Object	Looks like	Actually is	If found alone
Recovery Document	Ordinary printed web recipe; on a single A4 page	Quantum-generated pages carrying zero payload. Seed A's encrypted capsule lives transiently in private RAM	Encrypted text capsule lives transiently in private RAM
Vault Key Card	Generic bank, loyalty, membership or transport card	50 x 86 mm smart card containing Vault Key, signing key B, protected wallet state and MAC	Can protect wallet state and MAC
Terminal	Vintage-style scientific calculator	Air-gapped camera, decoder and Bitcoin signer with functional calculator in copy mode. No secret	Functional calculator in copy mode. No secret

Unauthenticated interrogation of the Vault Key Card MUST reveal no wallet-identifying descriptor, xpub or address-derivation information.

1.2 Wallet structure - native 2-of-2 multisig

Current wallet structure: P2WSH

```
wsh(multi(2, A, B))
```

Leg A

A 24-word BIP39 seed with BIP32 derivation. Seed A is stored only in encrypted form in the Recovery Document capsule and is reconstructed transiently inside terminal RAM.

The exact native-multisig derivation path/profile MUST be fixed before production funding and recorded in the descriptor, normative documentation where appropriate, and protocol-facing interoperability test material.

Leg B

Generated independently using the card secure element's RNG. Key B signs on-card and ordinarily never exists in terminal memory. Whether production leg B is fixed or derived remains a Gate B decision.

Descriptor

The complete wallet descriptor is stored sealed on every authorized card and echoed under the estate-storage rules. The descriptor is used to verify change outputs before signing. Unauthenticated access to the card MUST NOT disclose it.

Security interpretation

QuietKey uses a 2-of-2 multisig script, but it is not a multi-party custody system. Both signing components belong to the same owner.

The architecture provides physical separation, implementation separation, entropy-source independence, camouflage/discretion and recoverability. It does not provide threshold security against simultaneous possession of both required factors. An attacker possessing the matching Recovery Document and an authorized card can spend.

JavaCard ECDSA support makes native P2WSH the current wallet type. Taproot migration is a future card-applet/wallet-format question and MUST NOT appear in current acceptance criteria or UI examples.

1.3 Capsule and footer token - protocol version 0x02

Normative authority

docs/cloakvault-protocol-v3.md

docs/cloakvault-v3-test-vector.json

The design generation is called v3, while the wire-format version byte is 0x02. There is no protocol byte 0x03.

Capsule

Total length: 49 bytes

```
0x02 || ciphertext(32) || tag(16)
```

Encryption: AES-256-GCM-SIV. AAD: version byte. Nonce: fixed all-zero 12-byte nonce.

Capsule key derivation

HKDF-SHA256

- IKM: 256-bit Vault Key
- salt: empty
- info: UTF-8 CLOAKVAULT-V3-CAPSULE-KEY
- output: 32 bytes

Any authentication/decryption mismatch **MUST** fail closed. No partial recovery or guessed plaintext is permitted. The wallet fingerprint is calculated after successful decryption and is not stored in the capsule.

Deterministic-encryption rationale

Deterministic encryption exists deliberately so equivalent cards and redundant documents can reproduce byte-identical capsules. Equality leakage occurs only when the same seed is protected by the same Vault Key. An observer seeing equal capsules can therefore infer equality of the protected seed/key pair, but does not learn either value.

The fixed-nonce deterministic use of AES-GCM-SIV is a deliberate protocol decision and **MUST** remain an explicit Gate C external-audit target. A random nonce, larger retired capsule or alternative construction **MUST NOT** be silently substituted. Such a change requires a new protocol version.

Intentionally absent: stored nonce; KDF salt; capsule ID; stored fingerprint; key hint; generation counter.

Reed-Solomon layer

RS(83,49) over GF(2⁸); primitive polynomial 0x11D; generator roots alpha⁰ through alpha³³; systematic encoding; 34 parity bytes.

Correction condition:

```
2 * errors + erasures <= 34
```

A conforming reader **MUST convert uncertainty into an erasure and **MUST NOT** guess.**

Printed token

The 83-byte RS codeword is packed MSB-first into 133 Bech32 characters using:

```
qpzry9x8gf2tvdw0s3jn54khce6mua7l
```

It is framed by sentinel cv0 and a six-character BIP-173 checksum using HRP cv for checksum input only. Total printed token: 142 characters.

Line wrapping is presentation only. Extraction is structural and **MUST NOT** depend upon URL, domain, recipe, body text or document genre.

Error correction precedes checksum validation except where checksum consultation is used purely as a clean-capture fast path. A checksum **MUST NOT** discard a damaged token that remains recoverable through RS.

1.4 Recovery Document and camouflage boundary

The Recovery Document **MUST** be a genuinely useful, plausible, human-quality document. For v1 production, the primary cover genre is a printed recipe.

The recipe body carries zero payload. It is drawn from a curated corpus and **MUST NOT** be procedurally constrained by capsule bits. The cryptographic payload exists exclusively in the footer token.

Footer presentation

The token is visually dressed as an ordinary browser-print URL/identifier, accompanied where appropriate by mundane print metadata such as date and page number.

The intended human interpretation is:

This recipe was printed from a website and the user left the browser footer enabled.

The apparent URL is camouflage only.

- need not resolve
- MUST NOT be required to exist
- MUST NOT be queried during recovery
- MUST NOT create a DNS dependency
- MUST NOT create an HTTP dependency
- MUST NOT create any network dependency

QuietKey decoding works entirely from the structural token.

LLM boundary

LLM = interior designer, never architect.

An LLM may be used offline to help author, improve or diversify the curated cover corpus. It has no contact with capsule plaintext, no contact with the Vault Key, no control over token encoding, no control over token decoding and no cryptographic authority. No LLM runs on the terminal or recovery path.

Body/footer independence is a tested invariant.

Threat boundary

The cover is intended to resist casual and semi-informed recognition. It is not claimed to defeat funded forensic steganalysis.

The footer must therefore satisfy two independent requirements: machine readability and low human salience. Both are Gate A acceptance properties.

1.5 Seed generation

Seed A MUST combine at least two designated independent entropy sources:

- terminal SoC hardware RNG
- card secure-element RNG

Optional user dice may be added.

Independent sources are combined using a cryptographically specified conditioner. Security is preserved provided at least one designated source remains unpredictable to the adversary under the assumptions specified for the conditioner.

Dice input is an optional, user-verifiable contribution. Recommended advanced input: 99 d6 rolls, approximately 256 bits of raw dice outcome.

Dice MUST NOT be described as user-generated entropy and MUST NOT be presented as sufficient alone.

Runtime health tests apply separately to each designated electronic entropy source. The formal specification records conditioning construction, minimum-entropy assumptions, source independence assumptions, health-test behavior and deterministic test interface. A failed source is excluded loudly, never silently.

During creation the terminal displays a digest of each source contribution and the resulting reproducible wallet fingerprint.

Frozen v3 test-vector example: 3E1F-3AE0.

Key B is generated independently inside the secure element. Seed-generation and conditioning code is a named Gate C audit target.

1.6 Independent Recovery - mandatory

Every production QuietKey setup MUST create Independent Recovery.

Independent Recovery protects the combined 64-byte payload:

```
VaultKey || keyB
```

using two XOR shares.

Let $P = \text{VaultKey} || \text{keyB}$. Generate random Share A = R. Then Share B = $P \text{ XOR } R$.

Each share carries format version, wallet/generation binding, share index, share bytes and checksum. The shares MUST be distinguishable from BIP39 seeds and ordinary wallet mnemonics.

Sensitivity

Neither share alone reveals the protected payload. Together, Share A + Share B = equivalent sensitivity to the card's protected key material. Recovery Document + both shares permits complete wallet recovery and spending.

Shares MUST therefore be stored separately from each other and from the Recovery Document.

Recovery modes

Normal Recovery: Recovery Document + authorized card

Independent Recovery: Recovery Document + Share A + Share B + published specification/reference implementation

Destruction Test

Original terminal destroyed. All cards destroyed. Original QuietKey software unavailable.

Using only Recovery Document, Share A, Share B, published protocol and an independent implementation, the recoverer MUST reconstruct Seed A, Vault Key, key B and the wallet descriptor, and produce a valid native 2-of-2 spend. This is an acceptance criterion, not an aspirational feature.

1.7 KMAC and management authorization

QuietKey has no memorized PIN. This is deliberate. Ordinary spending requires the physical objects, not a memorized credential.

The Key Management Authorization Code (KMAC) governs privileged administrative operations, including provisioning and controlled key export.

KMAC properties

- full entropy
- stored
- never memorized
- protected according to estate rules

Verification locus

KMAC verification occurs inside the card. The terminal transports the credential. The secure element decides whether authorization succeeds. An attacker-controlled terminal MUST NOT be able to bypass the KMAC gate.

Wrong attempts

Incorrect KMAC attempts trigger an escalating delay. There is no permanent lockout.

With a correctly generated full-entropy KMAC, exhaustive guessing is computationally infeasible. Permanent lockout therefore adds little meaningful brute-force protection while enabling a trivial physical bricking attack. Brief access to a card **MUST NOT** allow a visitor to permanently destroy provisioning or rotation capability.

KMAC rotation

KMAC rotation is supported and requires current KMAC + physical presence of an authorized card. Possession of a copied KMAC alone therefore does not permit the attacker to replace the owner's credential. A suspected copied KMAC should be rotated while an authorized card remains available.

Lost KMAC

Loss of the KMAC does not endanger the Bitcoin. Normal spending remains Document + Card. Loss instead freezes management: no new-card provisioning and no management rotation requiring KMAC. The documented exit is to recover the wallet through Normal or Independent Recovery and rebuild into a fresh QuietKey vault.

Clone evidence

Every card maintains monotonic provisioning/rotation counters. The terminal displays those counters at every card insertion. Unexpected increments constitute compromise evidence. Counter baselines form part of the estate/security inventory and survive terminal replacement.

1.8 Security model

Assume the adversary knows the owner holds Bitcoin, knows QuietKey exists, understands its architecture, may photograph or copy Recovery Documents, may briefly obtain physical access to a card, may obtain an estate document and may control a hostile terminal implementation.

The cloak is never the cryptographic security boundary.

Document compromise

A copied Recovery Document reveals ciphertext. It does not reveal Seed A.

Card compromise

A card alone cannot produce a complete spend. Unauthenticated interrogation **MUST** reveal no wallet-identifying metadata.

Simultaneous compromise

Matching Document + authorized Card is sufficient to spend. Physical/geographic separation is therefore fundamental.

Blind-cosigner limitation

The card has no independent display and signs what the terminal presents. Therefore key B does not protect an active signing session against a fully malicious terminal.

Mitigations are full destination-address display, full amount display, fee display, change verification against descriptor, reproducible builds, Gate C audit and required anti-exfiltration mechanism.

Addresses **MUST** never be represented only in truncated form.

2. TERMINAL HARDWARE SPECIFICATION

2.1 Identity and decoy mode

Industrial-design target: vintage scientific calculator / professional instrument.

- HP-12C-like proportions
- brushed-metal faceplate
- dark bezel
- sculpted double-shot keys
- restrained two-colour legends
- fictitious model number
- no QuietKey branding

With no card inserted, the device boots exclusively into a fully functional scientific calculator. Card insertion acts as the physical transition into QuietKey functionality.

2.2 Envelope

Target external dimensions: 80 x 160 x 18 mm. Portrait orientation. Target mass: approximately 180 g including cells.

Vertical allocation: 8 mm upper margin; 34 mm display window; 4 mm gap; 68 mm keypad; remaining space in period-correct bezels.

Representative rear-to-front keypad stack: 1.8 mm shell; 5.5 mm SoM; 3.0 mm card plane/connector; 1.6 mm PCB; 4.0 mm switches/caps; 1.8 mm faceplate; total approximately 17.7 mm.

The display sits above the card zone.

Exterior openings are limited to keypad apertures, display, battery door, flush card door and 3.4 mm camera aperture.

NO USB. NO EXTERNAL DATA CONNECTOR.

2.3 Components

Subsystem	Specification	Requirement / rationale
Compute	CM-class Linux SoM; CM4/CM5 family or equivalent; no wireless SoM	Merit of silicon. SoM omits Ethernet jack and magnetics.
Display	480 x 320 IPS; about 73 x 49 mm active lands	Display area complete native P2WSH destination, amount, fee and change without truncation
Input	20 physical tactile switches; double-shot PBT	Physical long-life legends at 13.5 mm pitch. No touchscreen dependency.
Camera	IMX708 autofocus class; 3.4 mm countersunk	Camera aperture. 48-char x 3-line footer token; multi-frame recommended.
Card interface	ISO-7816 low-profile contact connector; side entry, flush spacing	ISO-7816 spacing accommodates card/camera depth arrangement; dust protection.
Power	4 x AAA L92 primary lithium; ~7.2 Wh	No rechargeable Li-ion/LiPo. User replaceable. Remove cells before long-term vaulting.
Data transfer	microSD inside battery compartment	Unsigned PSBT in; signed PSBT/document/update out. No external data connector.
Clock	None; no RTC coin cell	Signing needs no clock; avoids long-term coin-cell dependency.
Passives	Solid-polymer and ceramic preferred	Avoid drying electrolytics where practical.
Enclosure	Brushed-metal faceplate; PC/ABS body; mechanical fasteners	Sealed fasteners, no structural glue
Accessory case	Terminal only	MUST NOT store card or document; do not encourage co-location.

2.4 Firmware posture

Boot directly to application. No desktop environment.

- read-only root
- no swap
- no zram
- volatile paths on tmpfs
- secret buffers mlocked where technically available
- best-effort explicit zeroization

- core dumps disabled
- framebuffer cleared on sensitive-state transitions
- no secrets in command-line arguments
- no secrets in environment variables
- no secret logging

Builds MUST be reproducible. Offline updates are signed and enter only via microSD. No OTA mechanism exists.

Terminal hygiene acceptance

After a complete create/recover/sign cycle, forensic imaging of terminal storage finds zero seed/intermediate hits and network-interface enumeration shows loopback only. Gate A reader-confidence parameters become reproducible-build-controlled constants.

2.5 Operating flows

Calculator

No card: fully functional calculator only. No QuietKey UI is reachable.

Setup - Stage 1: wallet creation

Insert Card 1. Create wallet. Gather Seed A entropy according to section 1.5. Generate key B on-card. Derive Seed A. Construct wallet descriptor.

Setup - Stage 2: atomic provisioning phase

This phase is KMAC-gated. Within one controlled provisioning ceremony:

- provision Card 2
- perform the single one-time key-B export
- assemble the 64-byte VaultKey || keyB Independent Recovery payload
- create Share A and Share B
- store the sealed descriptor on both cards

The key-B export is a single event feeding both Card 2 provisioning and Independent Recovery share creation. The export window exists only inside this provisioning phase. It closes upon successful phase completion, phase exit or power interruption. Rotation is the only ordinary event that can reopen an authorized export opportunity.

Setup - Stage 3: verification

Before transient material is destroyed:

- recombine Share A and Share B from the actual stored representations
- verify reconstructed VaultKey || keyB
- verify reconstructed material yields the expected wallet descriptor
- verify Card 2's leg-B public key exactly equals Card 1's

Any mismatch aborts setup.

Setup - Stage 4: document

Select/render the curated zero-payload recipe body. Render the repeated footer token. Export. Print.

Setup - Stage 5: mandatory physical recovery test

Using the printed document, not the pre-print digital representation: photograph/capture token with QuietKey, use Card 1, recover Seed A, reconstruct wallet and verify expected fingerprint/descriptor.

Setup - Stage 6: estate completion

Create estate materials. Instruct separate storage of Independent Recovery shares. Record relevant card-management counter baselines. Zeroize Seed A and all transient raw key material.

Funding remains blocked until every setup and verification step succeeds.

Power interruption during provisioning

The atomic export phase MUST fail closed. After reboot the card MUST unambiguously report whether the one-time export event was consumed. No interruption state may leave raw export material persistently recoverable from the terminal, permit an unaccounted second export or silently create divergent Card 1/Card 2 key state. Gate B MUST specify and test the exact restart/recovery transition for every interruption point in the provisioning state machine.

Spend

1. Import unsigned PSBT by microSD.
2. Insert authorized card.
3. Capture footer token.
4. Locate token structurally.
5. Classify characters.
6. Mark low-confidence characters as erasures.
7. RS(83,49) decode.
8. Verify token checksum.
9. Authenticate/decrypt capsule.
10. Reconstruct Seed A in RAM.
11. Verify full destination address.
12. Verify amount.
13. Verify fee.
14. Verify change against sealed descriptor.
15. User confirms.
16. Terminal signs leg A.
17. Card signs leg B.
18. Export signed PSBT.
19. Zeroize Seed A.

Anti-exfiltration nonce contribution is mandatory. The exact host/card anti-exfiltration protocol MUST be fixed and reviewed before production funding.

Recovery and inheritance

Both Normal and Independent Recovery MUST pass the Stranger Test: a competent person unfamiliar with QuietKey can recover the wallet using the estate materials and published documentation without assistance from the original owner or manufacturer. Deliberate spend time remains approximately ten minutes.

2.6 Estate architecture

Estate Guide

Heir-accessible information explaining that an important digital-asset arrangement exists, which physical items are needed, basic recovery order and where authoritative public recovery instructions can be found. It SHOULD avoid unnecessary disclosure of exact high-security locations.

Security Inventory

Higher-security information containing as applicable: KMAC, exact card locations, Independent Recovery share locations, card identities, generation information, monotonic-counter baselines and descriptor-related estate records.

The Security Inventory is a high-value treasure map even though it cannot itself spend. It receives bank-box-class custody. The KMAC is not required for ordinary recovery/spending and therefore need not

travel with the basic heir-facing guide.

3. PROGRAM STATUS AND GATES

3.1 Foundation

Completed/merged foundation includes v3 capsule/footer codec, frozen normative specification, machine-readable vector, independent Python reimplementation, byte-exact interoperability, CI drift protection, TypeScript test suite, Python interoperability suite, Create, Recover, Shares, Self-Test, deterministic vector export and external design review.

QK2-04 does not reopen the completed codec architecture.

3.2 Gate A - physical capture and discretion

Gate A occurs before hardware/tooling freeze. It has two independent parts.

Gate A1 - machine capture

Print real production-format codec tokens including baseline pristine samples, deliberate damage samples and a 50 mm physical scale bar where appropriate for calibration.

Required print matrix

- laser printer
- inkjet printer
- high-quality paper
- ordinary office paper
- multiple print-quality settings
- 100% scale
- reduced scale representing realistic accidental print scaling

Required capture matrix

- current high-end phone camera
- older phone camera
- representative Android and iPhone devices
- direct capture
- mild perspective distortion
- stronger perspective distortion within plausible hand-held use
- normal indoor light
- low light
- uneven light
- glare
- mild defocus
- motion blur

Physical degradation

- folds
- wrinkles
- stains
- water exposure
- coffee-type staining

- partial character obstruction
- edge damage
- localized abrasion
- faded/low-contrast print
- partial page damage

Reader comparison

Compare stock OCR baseline with the intended confidence-aware QuietKey reader.

Mandatory reporting taxonomy

For every character: correctly recognized; detected erasure; silently incorrect.

For every token: RS-corrected errors; erasures; decode success; unrecoverable.

Silent misreads MUST be measured independently from erasures.

The experiment determines reader confidence floor, top-two candidate probability margin, empirical recoverability envelope and go/no-go decision. Those parameters become controlled protocol/build values where required.

Gate A2 - Human Salience Test

The same production-format documents MUST undergo unprimed human evaluation. Participants MUST NOT be told that the document contains hidden information, that QuietKey is being tested or that the footer is the object of interest.

Record whether anything is spontaneously described as unusual, whether the footer is noticed, what participants believe it represents, whether it causes them to assign unusual importance or value to the document and whether it is interpreted as ordinary browser/website print debris.

The intended spontaneous interpretation is approximately:

a recipe printed from a website with the URL/footer left on.

A participant noticing the footer is not automatically failure. The relevant question is whether it produces suspicion or perceived value rather than mundane dismissal.

The test MUST NOT be advertised as proving steganographic security. Its purpose is to empirically test the discretion claim.

Gate A2 acceptance criteria

Numerical thresholds are not invented in this blueprint. The pilot establishes a baseline; production acceptance thresholds are set before the definitive validation run so the project cannot move the goalposts after seeing results.

3.3 Gate B - smart-card applet

Gate B delivers and validates:

- secure-element key-B generation
- ECDSA signing
- sealed descriptor storage
- authenticated descriptor unsealing
- on-card KMAC verification
- escalating-delay wrong-attempt policy
- no permanent KMAC lockout
- KMAC rotation requiring current KMAC + authorized card

- monotonic provisioning/rotation counters
- counter display on every insertion
- atomic provisioning/export state machine
- power-loss safety
- Card 2 key-equivalence verification
- one-time export enforcement
- complete two-signature PSBT round trip

Gate B also resolves fixed versus derived leg B, exact native-P2WSH BIP32 derivation profile, sealed-descriptor mechanism, KMAC storage representation, KMAC rotation ceremony details and delay-schedule parameters.

3.4 Gate C - external code and hardware audit

Independent audit occurs against the built design, not merely the proposal.

Audit scope includes seed conditioning, entropy-source assumptions, deterministic AES-GCM-SIV rationale, equality leakage, reader conformance, RS/checksum ordering, card metadata non-disclosure, KMAC enforcement locus, KMAC retry behavior, provisioning state machine, power interruption, one-time export, clone/counter detection, blind-cosigner limitations, anti-exfiltration, reproducible builds, terminal secret hygiene, Independent Recovery and the complete Destruction Test.

Independent interoperability testing MUST extend through share recombination -> VaultKey/keyB reconstruction -> descriptor reconstruction -> valid 2-of-2 spend.

3.5 Phase 4 bench scope

Current bench baseline remains approximately EUR 347 BOM.

Current rationale: CM4-class no-wireless compute, physical keypad, no touchscreen dependency and system-hygiene controls.

The Gate A copy stand is a controlled experimental rig. A starting geometry such as approximately 250 mm / 352 ppi is an experimental starting point, not a production requirement.

The G2 path adds on-card leg-B generation, native 2-of-2 PSBT signing and PC/SC bench communication. G3 proves the complete two-signature round trip. No industrial tooling is authorized merely because the bench prototype works.

3.6 Recorded backlog

- multi-genre curated cover corpus
- user-supplied cover documents
- additional decoy-document variants
- one-to-one self-test row mapping for audit preparation
- production browser-print footer refinements after Gate A
- future Taproot/card-applet investigation

These MUST NOT delay the core validation path unless testing reveals they are necessary.

4. ACCEPTANCE AND RELEASE CRITERIA

Criterion	Pass condition
Protocol conformance	Frozen specification, vector, TypeScript and independent Python implementation agree byte-for-byte. Section 1.
Reader conformance	Uncertain characters become erasures; no semantic guessing; RS/checksum ordering correct; Gate A1 passes fr
Discretion conformance	Gate A2 demonstrates that the production-format document is ordinarily interpreted as mundane printed mater

Criterion	Pass condition
Card privacy	Unauthenticated interrogation reveals no descriptor, xpub or address-derived wallet metadata.
Secret hygiene	No wallet secret persists on terminal storage; post-cycle imaging finds zero seed/intermediate hits; only loopback
Setup completeness	Card 1 and Card 2 exist; leg-B public keys match; shares created in atomic export phase; shares recombined an
Provisioning safety	Power interruption cannot produce persistent raw export material, silent duplicate export, divergent accepted c
KMAC safety	Verification on-card; wrong attempts cannot permanently brick; rotation requires KMAC + authorized card; coun
Destruction Test	Document + both shares + published spec/reference implementation reconstruct Seed A, Vault Key, key B and
Stranger Test	An unfamiliar competent person can recover from the estate package and public materials without owner assist
Audit gate	All release-blocking Gate C findings are closed before real-funds designation.

5. PRODUCT RULES

QuietKey deliberately avoids feature proliferation. The production product **SHOULD** present one recommended architecture rather than asking ordinary users to design their own custody policy.

- No human-memory dependency.
- Never co-locate the Recovery Document and Vault Key Card.
- Independent Recovery is mandatory.
- The cloak is discretion, never cryptographic security.
- Test the actual printed recovery path before funding.
- Display complete transaction-critical information.
- Every unnecessary interface is a liability.

The current product deliberately excludes Wi-Fi, Bluetooth, NFC, external USB/data, cloud recovery, accounts, telemetry, BIP39 passphrase, memorized PIN, user-selectable cryptographic algorithms, default multi-party custody, QR-coded Recovery Documents, online recovery dependency, LLM involvement in cryptography and unnecessary user-selectable security modes.

6. ROTATION AND MAINTENANCE

6.1 Vault-Key rotation

Vault-Key rotation produces a new capsule/Recovery Document without requiring an on-chain Bitcoin move, subject to the normative protocol/card design.

Old Recovery Documents encrypted under old key material remain historical copies and do not magically become harmless merely because a new document exists. Rotation therefore includes a copy inventory and destruction/retirement ceremony for obsolete documents as appropriate.

6.2 Wallet rotation

Changing Seed A and/or the underlying wallet keys changes the wallet itself and requires an on-chain move. This is distinct from Vault-Key/document rotation.

6.3 Card maintenance

Cards are replaceable interfaces, but electronic longevity is finite. The maintenance guide **SHOULD** require periodic health verification and eventual migration to supported card generations. Independent Recovery exists specifically so long-term recoverability does not ultimately depend on an uninterrupted chain of compatible cards.

7. CURRENT OPEN DECISIONS

Gate / area	Decision or evidence still required
Gate A1	Reader confidence floor, top-two probability margin and empirical go/no-go envelope
Gate A2	Human-salience production acceptance thresholds after pilot baseline
Gate B	Fixed vs. derived leg B
Gate B	Exact native-P2WSH multisig derivation path/profile
Gate B	Sealed-descriptor mechanism
Gate B	KMAC storage form
Gate B	KMAC rotation ceremony details
Gate B	Wrong-attempt delay schedule
Gate B	Exact transactional/power-failure state machine
Signing	Exact reviewed anti-exfiltration protocol
Protocol audit	Final independent review of deterministic AES-GCM-SIV assumptions/equality leakage
Document output	Production browser-print wrapping, repetition and typography after Gate A

8. DEVELOPMENT ORDER

Phase	Purpose / status
1 - Protocol	Frozen specification and vectors. Foundation complete for current v3 codec.
2 - Reference implementation	Independent software implementations and interoperability. Foundation complete.
3 - Empirical document validation	Gate A1 machine capture + Gate A2 human salience. Current critical path.
4 - Bench hardware	Validate optics, keypad, display, power, microSD workflow, physical air gap and thermal envelope.
5 - Card applet	Gate B.
6 - Complete signing system	Native 2-of-2 PSBT workflow.
7 - Independent destruction recovery	Prove complete recovery outside the QuietKey hardware/software ecosystem.
8 - External audit	Gate C.
9 - Industrial design/tooling	Only after Gates A-C and all release-blocking findings pass.

9. NON-NEGOTIABLE TESTS

- Protocol Test: Independent implementations agree byte-for-byte.
- Reader Test: Real damaged printed documents recover within the specified empirical envelope.
- Human Salience Test: The cover/footer achieves the specified discretion target.
- Normal Recovery Test: Printed Document + Card reconstructs the expected wallet.
- Provisioning Test: Card 1, Card 2 and Independent Recovery all contain equivalent intended key material.
- Power-Failure Test: Every interruption point fails safely.
- KMAC Test: Authorization cannot be bypassed by a hostile terminal and cannot be trivially bricked through wrong attempts.
- Clone-Evidence Test: Unauthorized management activity produces detectable counter changes.
- Card-Privacy Test: Unauthenticated interrogation reveals no wallet-identifying metadata.
- Secret-Hygiene Test: Terminal storage reveals no secret after use.

- Stranger Test: A new person can execute documented recovery.
- Destruction Test: No original electronic QuietKey component or software is needed.
- Transaction Verification Test: Complete destination address, amount, fee and change are verified before signing.
- Adversarial Test: Assume the attacker knows exactly how QuietKey works.

10. SINGLE-SOURCE-OF-TRUTH RULE

System/device architecture

QK2-04 is the only current system-and-device blueprint.

Wire protocol

docs/cloakvault-protocol-v3.md plus docs/cloakvault-v3-test-vector.json remain the only normative protocol sources for the frozen current codec.

Executable proof

Independent TypeScript/Python implementations prove interoperability but do not independently redefine protocol constants.

Earlier project documents MUST be archived, clearly marked SUPERSEDED and removed from active implementation circulation.

Bench BOMs, CAD files, test plans and engineering notes may elaborate QK2-04 but cannot override it.

A change to a protocol constant requires a new protocol version, revised normative specification, new vector, updated independent implementations and renewed acceptance testing.

11. QK2-04 CONSOLIDATION RECORD - NON-NORMATIVE

QK2-04 carries forward the complete operative QK2-03 architecture. QK2-03 already consolidated the native 2-of-2 wallet, deterministic 49-byte capsule, RS(83,49) footer codec, zero-payload curated cover, multi-source entropy rules, mandatory Independent Recovery, card metadata privacy, current calculator hardware, physical air gap, gates and Destruction Test.

QK2-04 adds or tightens:

- A - Atomic provisioning/export ceremony: one controlled export event feeds Card 2 and Independent Recovery.
- B - Provisioning self-verification: share recombination, descriptor reconstruction and Card-1/Card-2 leg-B equality are tested before zeroization.
- C - Provisioning power-loss semantics: interrupted export fails closed and requires an unambiguous transactional state.
- D - Full KMAC lifecycle: card-side verification, escalating delays, no permanent lockout, rotation, loss behavior and counter surfacing.
- E - Human Salience Test: camouflage is now empirically tested rather than assumed.
- F - Expanded physical Gate A matrix: multiple printers, papers, cameras, optical conditions and physical degradation classes.
- G - Explicit inert-URL rule: the footer URL is camouflage only and introduces no network/domain dependency.
- H - Estate/security inventory clarification: KMAC, precise locations and management baselines receive higher-security treatment.

No frozen v3 codec constant is changed by QK2-04.

12. FINAL DESIGN STATEMENT

QuietKey is intentionally not a feature-rich hardware wallet. It is a narrow-purpose cold-storage instrument.

**The document contains encrypted information but no key.
The card contains cryptographic authority but not Seed A.
The terminal knows how to combine them but retains neither.**

To an uninformed observer they appear to be a recipe, a card and a calculator.

The system does not rely on an attacker remaining ignorant of QuietKey. It relies on established cryptography, physical separation, independent key material, authenticated recovery, tested redundancy and open recoverability.

The camouflage serves a different purpose: to make valuable things less likely to be recognized as valuable things.

The intended product experience remains deliberately simple:

Create. Print. Separate. Test. Store.

And the engineering philosophy remains equally simple:

Do not add a feature merely because it can be added. Every interface, option and dependency must justify the new failure mode it creates.

QK2-04 is the architecture to test - not another architecture to keep redesigning.